Contents

Volume 02 — Routing, Recon & Nessus (L11–L20) **1**
L11: Routing Protocols — Part I . . . 1
L12: Routing Protocols — Part II . . . 2
L13: Routing Protocols — Part III . . . 2
L14: IP Version 6 . . . 3
L15: Routing Examples . . . 3
L16: Demonstration — Part I . . . 4
L17: Demonstration — Part II . . . 4
L18: Demonstration — Part III . . . 5
L19: Nessus Installation . . . 6
L20: How to Use Nessus . . . 6

Volume 02 — Routing, Recon & Nessus (L11–L20)

Ethical Hacking · NPTEL 106105217 · Prof. Indranil Sengupta
notes-3 — concept exam notes (what things are / what they do). No lab command dumps.

Routing protocols, IPv6, OSINT/Nmap ideas, Nessus — what each is and does.

L11: Routing Protocols — Part I

What it is / what it does

- **Interior Gateway Protocols (IGP):** used within an autonomous system (AS).
- **RIP (Routing Information Protocol):** distance-vector; metric = hop count; max 15 hops; broadcasts updates every 30s.
- **Distance-vector characteristics:** "routing by rumor"; slow convergence; count-to-infinity problem.
- **Split horizon:** don't advertise route back to the interface it was learned from.
- **Route poisoning:** advertise failed route with metric 16 (infinity) to speed convergence.

Defenses (one-liners)

- Disable RIP on endpoints; use static routes where possible
- RIP authentication (plain-text or MD5)
- ACLs blocking UDP port 520 from untrusted sources

Exam lines

- RIP is a **distance-vector** protocol; metric = hop count (max 15).
- RIP uses **UDP port 520**; updates every 30 seconds.
- Split horizon prevents routing loops in simple topologies.
- Route poisoning sets failed route metric to 16 (unreachable).

- RIP v2 supports CIDR and multicast updates.

L12: Routing Protocols — Part II

What it is / what it does

- **OSPF (Open Shortest Path First):** link-state IGP; uses Dijkstra SPF algorithm.
- **Areas and ABR:** OSPF divides AS into areas; Area 0 = backbone; ABR connects areas.
- **LSA (Link State Advertisement):** routers flood topology database; build complete map.
- **OSPF packet types:** Hello, DBD (Database Description), LSR, LSU, LSAck.
- **Cost metric:** based on interface bandwidth (reference bandwidth / link bandwidth).

Defenses (one-liners)

- OSPF MD5 authentication on all adjacencies
- Passive interfaces on user-facing ports
- Route filtering and stub areas

Exam lines

- OSPF is **link-state**; builds complete topology map (vs RIP's partial view).
- OSPF uses **Dijkstra SPF** algorithm for shortest path.
- Area 0 is the OSPF **backbone**; all areas must connect to it.
- OSPF cost = reference bandwidth / interface bandwidth.
- OSPF Hello packets discover neighbors on same subnet.

L13: Routing Protocols — Part III

What it is / what it does

- **EIGRP (Enhanced IGRP):** Cisco proprietary (now partially open); hybrid (distance-vector + link-state features); DUAL algorithm.
- **BGP (Border Gateway Protocol):** exterior gateway protocol between ASes; path-vector; policy-based routing.
- **BGP attributes:** AS-PATH, NEXT-HOP, LOCAL-PREF, MED — used for route selection.
- **iBGP vs eBGP:** iBGP within same AS; eBGP between different ASes.
- **Convergence:** OSPF/EIGRP converge faster than RIP.

Defenses (one-liners)

- RPKI (Resource Public Key Infrastructure) — cryptographically validate prefix ownership

- BGP prefix filtering at peering edges
- MANRS (Mutually Agreed Norms for Routing Security)

Exam lines

- BGP is **path-vector**; operates between autonomous systems (inter-domain).
- BGP uses **TCP port 179** for peering sessions.
- AS-PATH attribute lists traversed autonomous systems (loop detection).
- EIGRP uses **DUAL** algorithm; supports unequal-cost load balancing.
- BGP hijacking can redirect global traffic to attacker infrastructure.

L14: IP Version 6

What it is / what it does

- **IPv6 address:** 128 bits, hex notation (2001:db8::1); eliminates NAT scarcity.
- **Address types:** unicast, multicast (no broadcast); anycast = nearest unicast.
- **Special addresses:** ::1 (loopback), fe80::/10 (link-local), fc00::/7 (unique local).
- **Neighbor Discovery Protocol (NDP):** replaces ARP; uses ICMPv6 (RS, RA, NS, NA).
- **SLAAC vs DHCPv6:** Stateless Address Autoconfiguration vs managed addressing.

Defenses (one-liners)

- RA Guard (filter rogue RAs on switch ports)
- SEND (Secure Neighbor Discovery) — cryptographically signed NDP
- IPv6 firewall rules (ip6tables/nftables)

Exam lines

- IPv6 address = **128 bits**; written in hexadecimal with : separators.
- NDP replaces **ARP** in IPv6 (uses ICMPv6).
- No broadcast in IPv6; uses **multicast** instead.
- Link-local prefix: **fe80::/10**.
- SLAAC auto-configures address from prefix in Router Advertisement.

L15: Routing Examples

What it is / what it does

- **Worked examples:** computing routing tables for small multi-router topologies.
- **Forwarding decision:** match destination IP against routing table → longest prefix → forward to next-hop.
- **Administrative distance (Cisco):** static=1, EIGRP=90, OSPF=110, RIP=120, external EIGRP=170, iBGP=200.
- **Route summarization:** aggregate /24s into /22 to reduce routing table size.

- **Floating static route:** backup route with higher metric, activated when primary fails.

Defenses (one-liners)

- Consistent security policy on primary and backup paths
- SNMPv3 with authentication
- Route summarization with prefix filtering

Exam lines

- Longest prefix match determines which route entry is used.
- Lower administrative distance = preferred route (Cisco).
- Route summarization reduces routing table size and update traffic.
- Floating static route activates only when primary route fails.
- Next-hop IP is the router to forward packet to (not necessarily final destination).

L16: Demonstration — Part I

What it is / what it does

- **Reconnaissance methodology:** passive (no direct target contact) vs active (generates traffic).
- **WHOIS lookup:** registrar, name servers, contact info, IP ranges.
- **DNS enumeration:** A, AAAA, MX, NS, TXT, SOA records.
- **Google dorking:** site:, filetype:, inurl: operators for OSINT.
- **Social media / job postings:** reveal technology stack and employee info.

Defenses (one-liners)

- Limit DNS zone transfer (AXFR)
- Employee security awareness training
- Minimize public-facing infrastructure details

Exam lines

- Passive recon generates **no traffic** to target (OSINT).
- dnsenum automates subdomain brute-forcing and zone transfer attempts.
- Google dorking uses advanced search operators for information discovery.
- Reconnaissance is the **first phase** of penetration testing.

L17: Demonstration — Part II

What it is / what it does

- **Active scanning:** directly probes target systems (generates logs).

- **Host discovery:** ICMP echo, ARP ping, TCP SYN to port 80/443.
- **Port scanning with Nmap:** identify open ports and running services.
- **Service version detection:** -sV probes banners and matches against nmap-service-probes DB.
- **OS fingerprinting:** -O analyzes TCP/IP stack behavior (TTL, window size, options).

Defenses (one-liners)

- Firewall rules limiting inbound connections
- Port knocking or single-entry bastion host
- IDS/IPS alerting on scan patterns
- Honeypots to detect and misdirect scanners

Exam lines

- -sV enables **service version detection**.
- -O performs **OS fingerprinting** (requires root for raw sockets).
- -A = aggressive scan (OS + version + scripts + traceroute).
- Active scanning **will be logged** by target IDS/firewall.

L18: Demonstration — Part III

What it is / what it does

- **Nmap Scripting Engine (NSE):** Lua scripts for vulnerability detection, brute-force, discovery.
- **Script categories:** auth, broadcast, brute, default, discovery, dos, exploit, external, fuzzer, intrusive, malware, safe, version, vuln.
- **Wireshark for scan analysis:** observe probe packets and target responses.
- **Firewall/IDS evasion:** fragment packets (-f), decoy scans (-D), slow scan (–scan-delay).
- **Output formats:** -oN (normal), -oX (XML), -oG (grepable).

Defenses (one-liners)

- Deep packet inspection (reassembles fragments)
- Rate-based scan detection
- Block NSE script signatures at WAF/IPS
- Log and alert on –script category traffic patterns

Exam lines

- NSE scripts written in **Lua**; run with –script flag.
- Script categories include: **vuln**, **brute**, **discovery**, **exploit**.
- -D RND:10 sends decoy packets to confuse logging.
- -f fragments packets to evade basic IDS rules.
- Wireshark captures reveal exact probe packets for forensic analysis.

L19: Nessus Installation

What it is / what it does

- **Nessus:** Tenable commercial vulnerability scanner (free Home/Essentials tier available).
- **Architecture:** Nessus server (scanner engine) + Nessus Manager (centralized, enterprise) + agents.
- **Scan types:** credentialed (authenticated) vs non-credentialed (remote/black-box).
- **Plugin feed:** vulnerability checks updated regularly (Professional vs Home feed).
- **Lab setup:** install on Kali or dedicated VM; requires registration for activation code.

Defenses (one-liners)

- Limit scanner access to authorized IP ranges
- Use credentialed scans for accurate patch-level assessment
- Schedule scans during maintenance windows
- Segment scanner VM on management VLAN

Exam lines

- Nessus runs as a **web service on port 8834** (HTTPS).
- **Credentialed scans** provide deeper results (patch levels, local checks).
- Plugin feed contains vulnerability check signatures.
- Nessus Essentials limits scanning to **16 IP addresses**.
- Initial plugin compilation is required after first installation.

L20: How to Use Nessus

What it is / what it does

- **Scan workflow:** New Scan → select template → configure targets → launch → review results.
- **Scan templates:** Basic Network Scan, Advanced Scan, Web App Tests, Malware Scan, Policy Compliance.
- **Severity ratings:** Critical, High, Medium, Low, Info (based on CVSS).
- **False positives:** verify findings manually before reporting.
- **Remediation:** Nessus provides CVE references, plugin output, and fix recommendations.

Defenses (one-liners)

- Patch management program addressing Nessus findings
- Compensating controls for unpatchable systems
- Regular rescanning to verify remediation

- WAF/IPS rules for web application findings

Exam lines

- Nessus severity maps to **CVSS scores** (Critical ≥ 9.0, High 7.0–8.9).
- **Advanced Scan** template allows full customization.
- Credentialed scans require SSH/Windows credentials on target.
- Plugin output shows exact check performed and evidence found.
- Always **verify findings** manually to reduce false positives in reports.